

Block 11c: build-variant and scanner review repairs

Date: 2026-09-28. Auditor: Codex /root. Isolated checkout: /private/tmp/kk715-11a. Immediate target: fork audit/715-11b-solana-runtime-20260928 at 51f99694f0cdde2151726a7fa252956a60ac1169 (PR #881). Code generation predecessor: b37a400ddfe7543910da8e50e49006e41455b3ed. Final containing head and hosted CI belong in the PR body. Main-worktree master template SHA256 at intake: 985cd8f5708e20ac34bf7442454b7ddb2271f5e9a2de048006dd75fb6f4c5556.

1. Scope and source reconciliation

This bounded unit extracts five unchanged paths from cumulative Block 11 after the first Copilot review 5333270562. It removes the broad ^deps/ scanner allowlist, places Pallas and ZIP-316 sources behind KK_ZCASH_PRIVACY, fixes emulator shared-library fallback paths to existing board sources, and removes the duplicate standalone zcash-crypto-unit target and its local RNG stub. Full firmware-unit retains the shared Zcash cases. The two exact public-gitlink no-git scanner ignores and report-authority test are inherited from approved prerequisite 11p, outside this adjacent diff. Product protocol, runtime handler and dependency pins do not change here.

Direct pins remain: code-signing-keys a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec; deps/crypto/trezor-firmware 8a392f70a5d5575ece3dfb35f115d4a4b27f497c; deps/device-protocol 5fec9e6906a340be5eb3d795ec746769065b2db8; deps/googletest 7888184f28509dba839e3683409443e0b5bb8948; deps/python-keepkey aae89d378d889b3872696469fe363cf570e5ac4c; deps/qrenc/QR-Code-generator 6dfbfadad5d9303ed190d1c3cb7bec34b565b6ce8; deps/sca-hardening/SecAESSTM32 71d356a1141624994cf613bd2d2583892e8e6d5a. Direct and nested submodules were initialized and checked clean before local builds.

2. Finding classes and verification

The scanner-sensitive value is a potential credential in a tracked dependency path; the observer is Gitleaks in CI. The old ^deps/ allowlist could suppress such a finding. In an isolated disposable deps/ fixture with a synthetic token, old configuration finds zero and fixed configuration finds one, with the value redacted. This is a configuration negative control, not a claim about an actual secret. Local Gitleaks is 8.30.0. A scan of a recursively populated local dependency tree also reports third-party fixture material outside the hosted clean superproject checkout; it is not used as the CI acceptance run. Hosted CI pins 8.30.1 and must pass on this exact PR head.

The build-sensitive state is product source composition. The old crypto source list included Pallas files before its Zcash option check, whereas the fixed full source graph contains Pallas and the Bitcoin-only graph excludes it. The old shared-library fallback referenced nonexistent emulator-relative strlcpy.c/strlcat.c; the fixed board-relative files exist and both compile with the pinned Linux Clang. A forced optional-dylib configure under the older Linux CMake stops at an unrelated cross-directory target-link ownership error before this target builds. The cumulative Windows cross-build is carried source evidence; this unit's hosted dylib build is the exact-head gate for the supported host. No Windows runtime execution is claimed.

The Zcash assertion is coverage preservation: the removed duplicate target does not remove the registered firmware suite. The full source graph builds unittests/firmware/zcash.cpp; 72/72 focused Zcash tests pass. Bitcoin-only excludes that product feature and has zero Zcash cases. The review's suggestion that all Zcash tests were absent is refuted by those executed cases; the redundant target itself was a valid cleanup. The source graph also shows no zcash-crypto-unit target after removal.

Local check	Full	Bitcoin-only	Outcome
Firmware native	669	143	All pass, zero failures/errors/skips
Crypto native	18	18	All pass, zero failures/errors/skips
Focused Zcash	72	0 by product	All full cases pass
Pallas source graph	Included	Excluded	Correct variant boundary
Scanner synthetic fixture	Old 0 / fixed 1	Same policy	Broad exemption removed

The deterministic sixteen-member 715-11c-controls-20260928.tgz archive has SHA256 41b4507721a651566a5705272cfabdc7a8f9f5a419e6602f1dc79933399a5e3. Its manifest binds fifteen raw XML/log/source-graph/control files and their hashes. A changed XML member is rejected. The related first-review control archive and every historical inline disposition remain available on cumulative PR #877.

3. Local and external checkpoint

The build-variant, Zcash coverage and scanner-configuration properties have current local assertions; native full and Bitcoin-only suites pass. The optional dylib fallback is verified by source-path and object compilation locally, with full target qualification delegated to exact-head hosted CI. Final post-edit preflight, hosted result, PDF/inventory check and Copilot delivery are recorded after report freeze in the PR body. This code-bearing unit has a fresh three-round review budget under the owner's consecutive split authority. No review has been requested here yet. Physical-device, merge and release acceptance remain separate.

4. Complete adjacent Git inventory

Inventory base: 51f99694f0cdde2151726a7fa252956a60ac1169. Code predecessor: b37a400ddfe7543910da8e50e49006e41455b3ed. The first containing report predecessor and final head are recorded in the PR body. Reproduce with `git diff --numstat 51f99694f0cdde2151726a7fa252956a60ac1169..FINAL_PR_HEAD`. Binary counts use Git's dash.

Added	Deleted	Path
-------	---------	------